BỘ CÔNG AN
CÔNG AN TP. HỒ CHÍ MINH

CỘNG HOÀ XÃ HỘI CHỦ NGHĨA VIỆT NAM
Độc lập - Tự do - Hạnh phúc

Số: 8771/CATP-PA05

TP. Hồ Chí Minh, ngày 03 tháng 10 năm 2026

V/v hướng dẫn tổ chức thực hiện bảo vệ an ninh mạng đối với hệ thống thông tin theo cấp độ

Kính gửi:
- Các Sở, Ban, Ngành;
- Ủy ban nhân dân các xã, phường, đặc khu Côn Đảo.

Thực hiện chức năng quản lý nhà nước về an ninh mạng, nhằm hỗ trợ các đơn vị triển khai đồng bộ, hiệu quả công tác bảo đảm an ninh mạng hệ thống thông tin, Công an Thành phố xây dựng hướng dẫn bảo đảm an ninh mạng cho các hệ thống thông tin trên địa bàn Thành phố Hồ Chí Minh. Tài liệu này hướng dẫn việc thực thi tổng thể, đồng bộ các biện pháp bảo đảm an ninh mạng cho các hệ thống thông tin thuộc phạm vi quản lý của các đơn vị, bao gồm các nội dung chính sau:

(1) Hướng tổ chức thực hiện bảo vệ an ninh mạng đối với hệ thống thông tin theo cấp độ và triển khai các biện pháp bảo vệ theo phương án được phê duyệt trong Hồ sơ đề xuất cấp độ;

(2) Tổ chức bảo đảm an ninh mạng theo mô hình 4 lớp;

(3) Các công tác khác có liên quan;

Một số nội dung chi tiết được hướng dẫn tại các phụ lục gửi kèm theo.

I. CĂN CỨ PHÁP LÝ

- Luật An ninh mạng số 116/2025/QH15 ngày 10/12/2025 của Quốc hội, có hiệu lực kể từ ngày 01/07/2026;

- Nghị định số 331/2026/NĐ-CP ngày 19/8/2026 của Chính phủ về bảo vệ an ninh mạng đối với hệ thống thông tin theo cấp độ *(gọi tắt là Nghị định số 331)*;

- Tiêu chuẩn quốc gia TCVN 14423:2026 về An ninh mạng - Hệ thống thông tin - Yêu cầu cơ bản.

- Công văn số 1552/BTTTT-CATTT ngày 28/4/2020 của Bộ Thông tin và Truyền thông (cũ) về đôn đốc tổ chức triển khai bảo đảm an toàn thông tin cho hệ thống thông tin theo mô hình "04 lớp".

- Công văn số 1598/BTTTT-CATTT ngày 28/4/2022 của Bộ Thông tin và Truyền thông về tăng cường bảo đảm an toàn thông tin theo cấp độ và nâng cao năng lực bảo đảm an toàn theo mô hình "04 lớp".

II. GIẢI THÍCH TỪ NGỮ

Trong Văn bản này, các từ ngữ dưới đây được hiểu như sau:

1. *Xử lý thông tin* là việc thực hiện một hoặc một số thao tác tạo lập, cung cấp, truyền đưa, thu thập, xử lý, lưu trữ, chia sẻ và trao đổi thông tin trên không gian mạng.

2. *Đơn vị chuyên trách về an ninh mạng* là đơn vị có chức năng, nhiệm vụ bảo đảm an ninh mạng của chủ quản hệ thống thông tin.

3. *Bộ phận chuyên trách về an ninh mạng* là bộ phận thuộc đơn vị chuyên trách về công nghệ thông tin hoặc chuyển đổi số, do chủ quản hệ thống thông tin thành lập hoặc chỉ định để thực thi nhiệm vụ bảo đảm an ninh mạng và ứng phó sự cố an ninh mạng (trường hợp không thành lập được đơn vị chuyên trách về an ninh mạng).

4. *Cấp độ an ninh mạng hệ thống thông tin* được hiểu là cấp độ hệ thống thông tin.

5. *Dịch vụ trực tuyến* là dịch vụ do doanh nghiệp hoặc cơ quan nhà nước cung cấp trên môi trường mạng cho các tổ chức, cá nhân.

III. NGUYÊN TẮC BẢO ĐẢM AN NINH MẠNG HỆ THỐNG THÔNG TIN THEO CẤP ĐỘ

1. Việc bảo đảm an ninh mạng hệ thống thông tin theo cấp độ trong hoạt động của cơ quan, tổ chức được thực hiện thường xuyên, liên tục từ khâu thiết kế, xây dựng, vận hành đến khi hủy bỏ; tuân thủ theo tiêu chuẩn, quy chuẩn kỹ thuật.

2. Việc bảo đảm an ninh mạng hệ thống thông tin theo cấp độ trong hoạt động của cơ quan, tổ chức được thực hiện một cách tổng thể, đồng bộ, tập trung trong việc đầu tư các giải pháp bảo vệ, có sự dùng chung, chia sẻ tài nguyên để tối ưu hiệu năng, tránh đầu tư thừa, trùng lặp.

3. Việc phân bổ, bố trí nguồn lực để bảo đảm an ninh mạng hệ thống thông tin thực hiện theo thứ tự ưu tiên từ cấp độ cao xuống cấp độ thấp.

4. Bộ Quốc phòng quản lý về an ninh mạng với nhiệm vụ quân sự, quốc phòng; Bộ Công an quản lý về an ninh mạng đối với các hoạt động dân sự, kinh tế của các đơn vị quân đội theo thẩm quyền; các nội dung giao thoa (nếu có), Bộ Công an và Bộ Quốc phòng thống nhất bằng quy chế phối hợp.

IV. TRÁCH NHIỆM CỦA CÁC BÊN

1. Trách nhiệm của chủ quản hệ thống thông tin

1.1. Người đứng đầu của cơ quan, tổ chức là chủ quản hệ thống thông tin có trách nhiệm:

- Trực tiếp chỉ đạo và chịu trách nhiệm trước pháp luật về công tác bảo vệ an ninh mạng trong hoạt động của cơ quan, tổ chức mình;

- Bố trí bộ phận hoặc nhân sự chuyên trách về an ninh mạng phù hợp với

cấp độ bảo vệ của hệ thống; chỉ định cá nhân, bộ phận phụ trách về an ninh mạng đối với hệ thống sử dụng ngân sách nhà nước;

- Trong trường hợp chưa có đơn vị chuyên trách về an ninh mạng độc lập:

+ Chỉ định đơn vị chuyên trách về công nghệ thông tin hoặc chuyển đổi số làm nhiệm vụ đơn vị chuyên trách về an ninh mạng;

+ Thành lập hoặc chỉ định bộ phận chuyên trách về an ninh mạng.

1.2. Chủ quản hệ thống thông tin có trách nhiệm:

- Chỉ đạo đơn vị vận hành hệ thống thông tin xác định, lập hồ sơ đề xuất cấp độ hệ thống thông tin, hệ thống thông tin quan trọng về an ninh quốc gia; tổ chức thẩm định và phê duyệt hồ sơ đề xuất cấp độ theo quy định tại Nghị định số 331;

- Chỉ đạo, tổ chức thực hiện đầy đủ các nhiệm vụ, biện pháp bảo vệ an ninh mạng đối với hệ thống thông tin quy định tại Nghị định số 331 và quy định của pháp luật có liên quan;

- Chỉ đạo, tổ chức thực hiện kiểm tra, đánh giá an ninh mạng và quản lý rủi ro an ninh mạng trong phạm vi cơ quan, tổ chức của mình; đồng thời, chịu trách nhiệm trước pháp luật về tính trung thực, đầy đủ và chính xác của kết quả đánh giá, cụ thể như sau:

+ Việc kiểm tra, đánh giá an ninh mạng và quản lý rủi ro an ninh mạng có thể được thực hiện theo hình thức tự đánh giá nội bộ, với điều kiện việc đánh giá phải do bộ phận hoặc đơn vị độc lập với đơn vị trực tiếp vận hành hệ thống thực hiện, tuân thủ biểu mẫu, tiêu chí và phương pháp đánh giá do cơ quan nhà nước có thẩm quyền ban hành;

+ Việc kiểm tra, đánh giá bởi tổ chức chuyên môn được cơ quan có thẩm quyền cấp phép; tổ chức sự nghiệp nhà nước có chức năng, nhiệm vụ phù hợp hoặc do tổ chức chuyên môn được cấp có thẩm quyền chỉ định thực hiện được thực hiện trong các trường hợp sau đây: hệ thống thông tin cấp độ 5 hoặc hệ thống thông tin quan trọng về an ninh quốc gia; khi xảy ra sự cố an ninh mạng nghiêm trọng hoặc có nguy cơ cao ảnh hưởng đến an ninh quốc gia, trật tự, an toàn xã hội; khi có thay đổi lớn về chức năng, phạm vi, kiến trúc hoặc công nghệ của hệ thống thông tin; khi có dấu hiệu việc tự đánh giá không bảo đảm tính trung thực, đầy đủ, chính xác; khi có yêu cầu của cơ quan nhà nước có thẩm quyền hoặc do chủ quản hệ thống thông tin tổ chức thực hiện;

- Báo cáo sự cố an ninh mạng với cơ quan chuyên trách của Bộ Công an (đối với hệ thống do Bộ Quốc phòng quản lý, chủ quản hệ thống báo cáo sự cố về lực lượng chuyên trách bảo vệ an ninh mạng thuộc Bộ Quốc phòng để phối hợp xử lý theo thẩm quyền):

+ Báo cáo về nguyên nhân, phạm vi ảnh hưởng, biện pháp khắc phục trong thời hạn 72 giờ kể từ thời điểm phát hiện sự cố; trường hợp sự cố phức tạp, chủ quản hệ thống thông tin báo cáo thông tin sơ bộ, biện pháp khắc phục và gửi báo

cáo cập nhật, báo cáo kết thúc sau khi hoàn thành điều tra, khắc phục và đánh giá tác động;

+ Thông báo ban đầu về sự cố an ninh mạng nghiêm trọng trong thời hạn 24 giờ kể từ khi phát hiện;

+ Trường hợp sự cố có dấu hiệu xâm phạm an ninh quốc gia, trật tự, an toàn xã hội hoặc gây gián đoạn nghiêm trọng hoạt động của hệ thống thông tin, việc báo cáo phải được thực hiện ngay khi phát hiện.

- Chỉ đạo tổ chức tuyên truyền, nâng cao nhận thức về an ninh mạng; thường xuyên bồi dưỡng, cập nhật kỹ năng cho đội ngũ nhân sự liên quan, cụ thể như sau:

- Đào tạo, bồi dưỡng theo các chương trình đào tạo ngắn hạn nâng cao kiến thức, kỹ năng về an ninh mạng cho cán bộ, công chức, viên chức làm về an ninh mạng trong cơ quan, tổ chức mình;

- Tuyên truyền, phổ biến nâng cao nhận thức về an ninh mạng cho cán bộ, công chức, viên chức trong cơ quan, tổ chức mình;

- Diễn tập bảo đảm an ninh mạng trong hoạt động của cơ quan, tổ chức mình; tham gia diễn tập quốc gia và diễn tập quốc tế do Bộ Công an tổ chức.

- Đối với hệ thống thông tin quân sự, việc kiểm tra, đánh giá an ninh mạng và đánh giá rủi ro an ninh mạng đối với hệ thống từ cấp độ 3 trở lên do Bộ Quốc phòng tổ chức thực hiện thông qua bộ phận chuyên trách về an ninh mạng hoặc tổ chức chuyên môn do Bộ Quốc phòng chỉ định, phù hợp với quy định riêng của Bộ Quốc phòng về bảo vệ an ninh mạng.

2. Trách nhiệm của đơn vị chuyên trách về an ninh mạng

- Tham mưu, tổ chức thực thi, đôn đốc, kiểm tra, giám sát công tác bảo vệ an ninh mạng tại cơ quan, tổ chức.

- Phối hợp với lực lượng chuyên trách bảo vệ an ninh mạng trong việc thực hiện kiểm tra, đánh giá, giám sát và ứng cứu sự cố an ninh mạng.

- Bảo đảm người thực hiện nhiệm vụ an ninh mạng đáp ứng tiêu chuẩn chuyên môn, nghiệp vụ theo quy định tại Luật An ninh mạng.

- Thẩm định, phê duyệt hoặc cho ý kiến về mặt chuyên môn đối với hồ sơ đề xuất cấp độ theo thẩm quyền.

- Phối hợp đơn vị vận hành hệ thống thông tin kiểm tra, đánh giá an ninh mạng và quản lý rủi ro về an ninh mạng; dò quét phát hiện điểm yếu, lỗ hổng bảo mật; kiểm thử xâm nhập đối với các hệ thống thuộc phạm vi quản lý.

3. Trách nhiệm của đơn vị vận hành hệ thống thông tin

- Thực hiện các biện pháp để bảo vệ an ninh mạng theo phương án đã được chủ quản hệ thống thông tin phê duyệt và theo quy định tại Điều 10 Luật An ninh mạng.

- Thực hiện bảo vệ hệ thống thông tin theo quy định của pháp luật và hướng

dẫn, tiêu chuẩn, quy chuẩn kỹ thuật về an ninh mạng.

- Định kỳ đánh giá hiệu quả của các biện pháp bảo vệ an ninh mạng, báo cáo chủ quản hệ thống thông tin điều chỉnh nếu cần thiết.

- Phối hợp đơn vị hoặc bộ phận chuyên trách về an ninh mạng tiến hành xử lý, khắc phục các điểm yếu, lỗ hổng bảo mật, nguy cơ mất an ninh mạng trong hệ thống.

- Phối hợp thực hiện theo hướng dẫn của Cục An ninh mạng - Bộ Công an trong công tác bảo đảm an ninh mạng và thiết lập hệ thống kết nối, đấu nối đường truyền kỹ thuật, truyền tải dữ liệu và đáp ứng các điều kiện cần thiết khác phục vụ giám sát an ninh mạng (trừ hệ thống thông tin quân sự và hệ thống thông tin cơ yếu thuộc Ban Cơ yếu Chính phủ theo quy định của pháp luật).

- Định kỳ hoặc đột xuất báo cáo công tác thực thi bảo đảm an ninh mạng hệ thống thông tin theo yêu cầu của chủ quản hệ thống thông tin hoặc cơ quan quản lý nhà nước chuyên ngành có thẩm quyền.

V. TIÊU CHÍ XÁC ĐỊNH HỆ THỐNG THÔNG TIN

1. Xác định chủ quản hệ thống thông tin

- Đối với Ủy ban nhân dân Thành phố và các đơn vị trực thuộc, chủ quản hệ thống thông tin là:

+ Ủy ban nhân dân Thành phố;

+ Đơn vị được giao thẩm quyền quyết định đầu tư dự án xây dựng, thiết lập, nâng cấp, mở rộng hệ thống thông tin. Ủy ban nhân dân Thành phố quyết định chủ quản hệ thống thông tin theo quy định của khoản 1 Điều 4 Nghị định số 331, bảo đảm cơ quan, tổ chức trực thuộc được giao chủ quản hệ thống thông tin có đủ năng lực để thực thi đầy đủ các quy định tại Điều 31 Nghị định số 331.

- Đối với doanh nghiệp và tổ chức khác, chủ quản hệ thống thông tin là cấp có thẩm quyền quyết định đầu tư xây dựng, thiết lập, nâng cấp, mở rộng hệ thống thông tin.

- Trong trường hợp cần thiết, chủ quản hệ thống thông tin ủy quyền cho một tổ chức trực thuộc có đủ năng lực để thay mặt thực hiện trách nhiệm của chủ quản hệ thống thông tin quy định tại khoản 2 Điều 31 Nghị định số 331. Việc ủy quyền trách nhiệm chủ quản hệ thống thông tin phải được thực hiện bằng văn bản, trong đó nêu rõ phạm vi của hệ thống, trách nhiệm của tổ chức được ủy quyền và thời hạn ủy quyền.

2. Xác định đơn vị vận hành

- Đơn vị vận hành hệ thống thông tin là đơn vị được chủ quản hệ thống thông tin giao nhiệm vụ vận hành hệ thống thông tin.

- Trong trường hợp hệ thống thông tin gồm nhiều hệ thống thành phần hoặc phân tán, có nhiều hơn một đơn vị vận hành hệ thống thông tin, chủ quản hệ thống

thông tin có trách nhiệm chỉ định một đơn vị chủ trì thực hiện quyền và nghĩa vụ của đơn vị vận hành hệ thống thông tin theo quy định của pháp luật.

- Trong trường hợp thuê dịch vụ công nghệ thông tin, đơn vị vận hành hệ thống thông tin được xác định như sau:

+ Trường hợp đã xác định được đơn vị cung cấp dịch vụ theo quy định của pháp luật, đơn vị vận hành được xác định theo thỏa thuận trong hợp đồng giữa các bên; hợp đồng phải quy định chi tiết trách nhiệm, thẩm quyền của các bên trong quản trị dữ liệu, kiểm soát truy cập, bảo đảm an ninh mạng, bảo đảm phù hợp với quy định của pháp luật dân sự và pháp luật về an ninh mạng;

+ Trường hợp hết thời hạn cung cấp dịch vụ, nếu hệ thống thông tin vẫn tiếp tục duy trì hoạt động, đơn vị vận hành được xác định theo các điều khoản cam kết duy trì, chuyển giao dịch vụ trong hợp đồng hoặc theo thỏa thuận mới giữa các bên;

+ Trường hợp khác, đơn vị chủ trì thuê dịch vụ đóng vai trò là đơn vị vận hành.

3. Xác định đơn vị chuyên trách về an ninh mạng

- Đơn vị chuyên trách về an ninh mạng là đơn vị có chức năng, nhiệm vụ bảo đảm an ninh mạng của chủ quản hệ thống thông tin.

- Chủ quản hệ thống thông tin chỉ định hoặc thành lập đơn vị chuyên trách về an ninh mạng để thực hiện các trách nhiệm tại mục 2 Phần IV của Công văn này.

4. Xác định và phân loại hệ thống thông tin

4.1. Xác định hệ thống thông tin

- Hệ thống thông tin phải có chức năng nghiệp vụ rõ ràng; có xử lý dữ liệu; có người dùng, đối tượng vận hành hoặc đối tượng phục vụ cụ thể; có kết quả đầu ra dưới dạng thông tin, dữ liệu phục vụ hoạt động quản lý, điều hành, giao dịch hoặc cung cấp dịch vụ.

- Phạm vi của hệ thống thông tin:

+ Phạm vi của hệ thống thông tin phải được xác định trên cơ sở: chức năng nghiệp vụ (cùng phục vụ một chức năng hoặc quy trình nghiệp vụ cốt lõi); dòng chảy và mối liên kết dữ liệu (có trao đổi dữ liệu thường xuyên, liên tục hoặc phụ thuộc lẫn nhau trong xử lý); mức độ phụ thuộc trong vận hành (không thể vận hành độc lập mà không làm gián đoạn hoạt động của thành phần khác); phạm vi và mức độ ảnh hưởng khi xảy ra sự cố (sự cố của một thành phần có thể ảnh hưởng đến tính toàn vẹn hoặc làm gián đoạn chức năng, quy trình nghiệp vụ cốt lõi của toàn bộ hệ thống thông tin);

+ Việc xác định phạm vi hệ thống thông tin phải phản ánh đúng bản chất vận hành thực tế, không phụ thuộc vào cách tổ chức hành chính, mô hình triển khai kỹ thuật hoặc cấu trúc hạ tầng vật lý. Trường hợp các hệ thống có kết nối, liên thông dữ liệu hoặc chia sẻ tài nguyên hạ tầng, việc xác định phạm vi hệ thống phải xem xét khả năng lan truyền rủi ro và ảnh hưởng dây chuyền.

4.2 Phân loại hệ thống thông tin

- Thông tin xử lý qua hệ thống thông tin được phân loại theo thuộc tính bí mật như sau:

+ Thông tin công cộng là thông tin trên mạng của một tổ chức, cá nhân được công khai cho tất cả các đối tượng mà không cần xác định danh tính, địa chỉ cụ thể của các đối tượng đó;

+ Thông tin riêng là thông tin trên mạng của một tổ chức, cá nhân mà tổ chức, cá nhân đó không công khai hoặc chỉ công khai cho một hoặc một nhóm đối tượng đã được xác định danh tính, địa chỉ cụ thể;

+ Thông tin cá nhân là thông tin trên mạng gắn với việc xác định danh tính một người cụ thể;

+ Thông tin bí mật nhà nước là thông tin ở mức Mật, Tối Mật, Tuyệt Mật theo quy định của pháp luật về bảo vệ bí mật nhà nước.

- Hệ thống thông tin được phân loại theo chức năng phục vụ hoạt động nghiệp vụ như sau:

+ Hệ thống thông tin phục vụ hoạt động nội bộ là hệ thống chỉ phục vụ hoạt động quản trị, vận hành nội bộ của cơ quan, tổ chức;

+ Hệ thống thông tin phục vụ người dân, doanh nghiệp là hệ thống trực tiếp hoặc hỗ trợ cung cấp dịch vụ trực tuyến, bao gồm dịch vụ công trực tuyến và dịch vụ trực tuyến khác trong các lĩnh vực viễn thông, công nghệ thông tin, thương mại, tài chính, ngân hàng, y tế, giáo dục và các lĩnh vực chuyên ngành khác;

+ Hệ thống cơ sở hạ tầng thông tin là tập hợp trang thiết bị, đường truyền dẫn kết nối phục vụ chung hoạt động của nhiều cơ quan, tổ chức như mạng diện rộng, cơ sở dữ liệu, trung tâm dữ liệu, điện toán đám mây; xác thực điện tử, chứng thực điện tử, chữ ký số; kết nối liên thông các hệ thống thông tin;

+ Hệ thống thông tin điều khiển công nghiệp là hệ thống có chức năng giám sát, thu thập dữ liệu, quản lý và kiểm soát các hạng mục quan trọng phục vụ điều khiển, vận hành hoạt động bình thường của các công trình xây dựng;

+ Hệ thống thông tin khác là hệ thống thông tin không thuộc các loại hình được nêu phía trên, được sử dụng để trực tiếp phục vụ hoặc hỗ trợ hoạt động nghiệp vụ, sản xuất, kinh doanh cụ thể của cơ quan, tổ chức theo lĩnh vực chuyên ngành;

+ Định kỳ hằng năm (trước ngày 15 tháng 01), Bộ Công an có trách nhiệm cập nhật, bổ sung danh mục các hệ thống thông tin theo quy định tại các điểm a, b, c, d, đ khoản này và công bố trên Cổng thông tin điện tử của Bộ Công an (trừ hệ thống thông tin quân sự và hệ thống thông tin cơ yếu thuộc Ban Cơ yếu Chính phủ).

5. Đánh giá rủi ro an ninh mạng

- Quản lý rủi ro an ninh mạng là quá trình xác định, đánh giá, xử lý và kiểm soát các rủi ro có thể gây tổn hại đến an ninh mạng của hệ thống thông tin, làm căn cứ hỗ trợ xác định cấp độ hệ thống thông tin và áp dụng biện pháp bảo đảm an ninh mạng phù hợp.

- Chủ quản hệ thống thông tin có trách nhiệm thực hiện đánh giá rủi ro an ninh mạng trong các trường hợp sau đây:

+ Khi xác định cấp độ hệ thống thông tin lần đầu;

+ Khi có thay đổi về chức năng, phạm vi phục vụ, đối tượng sử dụng, loại thông tin xử lý hoặc công nghệ triển khai hệ thống thông tin;

+ Khi hệ thống thông tin mở rộng quy mô, tích hợp, kết nối liên thông hoặc chia sẻ dữ liệu với hệ thống khác;

+ Khi xảy ra sự cố an ninh mạng nghiêm trọng hoặc có nguy cơ cao ảnh hưởng đến an ninh quốc gia, trật tự, an toàn xã hội, lợi ích công cộng;

+ Khi có yêu cầu của cơ quan nhà nước có thẩm quyền.

- Nội dung đánh giá rủi ro an ninh mạng bao gồm tối thiểu các yếu tố sau đây:

+ Xác định tài sản, chức năng trọng yếu, vai trò của tài sản trong hệ thống thông tin và phân loại tài sản theo thứ tự quan trọng trong hệ thống thông tin;

+ Xác định loại thông tin được xử lý, lưu trữ, truyền đưa qua hệ thống, bao gồm thông tin công cộng, thông tin riêng, thông tin cá nhân, thông tin bí mật nhà nước;

+ Nhận diện rủi ro an ninh mạng dựa trên xác định mối đe dọa, điểm yếu, lỗ hổng bảo mật và khả năng bị khai thác;

+ Đánh giá khả năng xảy ra sự cố và mức độ tác động, hậu quả đối với an ninh quốc gia, trật tự, an toàn xã hội, quyền và lợi ích hợp pháp của tổ chức, cá nhân, lợi ích công cộng;

+ Đánh giá năng lực hiện có trong việc phòng ngừa, phát hiện, ứng phó và khắc phục sự cố an ninh mạng;

+ Xây dựng kế hoạch và triển khai các biện pháp giảm thiểu rủi ro tương ứng với các rủi ro đã xác định;

+ Thực hiện truyền thông rủi ro và báo cáo đến cơ quan có thẩm quyền.

- Kết quả đánh giá rủi ro an ninh mạng là căn cứ để:

+ Đề xuất, xác định hoặc điều chỉnh cấp độ hệ thống thông tin theo quy định tại các Điều 11 đến Điều 16 Nghị định số 331;

+ Lựa chọn, triển khai biện pháp bảo đảm an ninh mạng tương ứng với cấp độ hệ thống thông tin;

+ Xây dựng, điều chỉnh phương án bảo vệ hệ thống thông tin, phương án ứng cứu sự cố an ninh mạng.

- Trường hợp kết quả đánh giá rủi ro an ninh mạng cho thấy mức độ rủi ro cao hơn so với cấp độ đã được xác định, chủ quản hệ thống thông tin phải đề xuất áp dụng cấp độ cao hơn để bảo đảm an ninh mạng.

- Chủ quản hệ thống thông tin có trách nhiệm lưu giữ hồ sơ đánh giá rủi ro an ninh mạng và cung cấp cho cơ quan nhà nước có thẩm quyền khi phục vụ công tác thanh tra, kiểm tra, giám sát theo quy định của pháp luật.

- Cơ quan nhà nước có thẩm quyền, đơn vị chức năng căn cứ kết quả đánh giá rủi ro an ninh mạng để yêu cầu hay đề xuất chủ quản hệ thống thông tin rà soát, đánh giá lại cấp độ hệ thống thông tin và áp dụng biện pháp bảo đảm an ninh mạng phù hợp trong trường hợp cần thiết.

- Việc đánh giá rủi ro an ninh mạng được thực hiện theo quy định của Bộ trưởng Bộ Công an (trừ hệ thống thông tin quân sự và hệ thống thông tin cơ yếu thuộc Ban Cơ yếu Chính phủ).

6. Xác định cấp độ của hệ thống thông tin

6.1. Tiêu chí xác định cấp độ 1

- Hệ thống thông tin cấp độ 1 là hệ thống phục vụ hoạt động nội bộ của cơ quan, tổ chức và chỉ xử lý thông tin công cộng.

- Hệ thống thông tin được đánh giá rủi ro an ninh mạng theo Khung quản lý rủi ro an ninh mạng.

6.2. Tiêu chí xác định cấp độ 2

Hệ thống thông tin cấp độ 2 là hệ thống thông tin có một trong các tiêu chí cụ thể sau:

- Hệ thống thông tin phục vụ hoạt động nội bộ của cơ quan, tổ chức và có xử lý thông tin riêng, thông tin cá nhân của người sử dụng nhưng không xử lý thông tin bí mật nhà nước.

- Hệ thống thông tin phục vụ người dân, doanh nghiệp thuộc một trong các loại hình như sau:

+ Cung cấp dịch vụ trực tuyến không thuộc danh mục ngành, nghề đầu tư kinh doanh có điều kiện;

+ Cung cấp dịch vụ trực tuyến khác có xử lý thông tin riêng, thông tin cá nhân của dưới 100.000 chủ thể dữ liệu đối với dữ liệu cá nhân cơ bản hoặc dưới 10.000 chủ thể dữ liệu đối với dữ liệu cá nhân nhạy cảm.

- Hệ thống cơ sở hạ tầng thông tin phục vụ hoạt động của một cơ quan, tổ chức.

- Hệ thống thông tin khác do Thủ tướng Chính phủ quyết định hoặc được đánh giá rủi ro an ninh mạng theo Khung quản lý rủi ro an ninh mạng.

6.3. Tiêu chí xác định cấp độ 3

Hệ thống thông tin cấp độ 3 là hệ thống có một trong các tiêu chí sau:

- Hệ thống xử lý thông tin bí mật nhà nước hoặc hệ thống phục vụ quốc phòng, an ninh khi bị phá hoại sẽ làm tổn hại tới an ninh quốc gia.

- Hệ thống thông tin phục vụ người dân, doanh nghiệp thuộc một trong các loại hình như sau:

+ Cung cấp dịch vụ trực tuyến thuộc danh mục ngành, nghề đầu tư kinh doanh có điều kiện;

+ Hệ thống thông tin giải quyết thủ tục hành chính;

+ Cung cấp dịch vụ trực tuyến khác có xử lý thông tin riêng, thông tin cá nhân của từ 100.000 chủ thể dữ liệu đối với dữ liệu cá nhân cơ bản trở lên hoặc từ 10.000 chủ thể dữ liệu đối với dữ liệu cá nhân nhạy cảm trở lên.

- Hệ thống cơ sở hạ tầng thông tin phục vụ hoạt động của các cơ quan, tổ chức trong phạm vi một bộ, một ngành, một tỉnh hoặc một số tỉnh.

- Hệ thống thông tin điều khiển công nghiệp trực tiếp phục vụ điều khiển, vận hành hoạt động bình thường của các công trình xây dựng cấp II, cấp III hoặc cấp IV theo phân cấp của pháp luật về xây dựng.

- Hệ thống thông tin khác do Thủ tướng Chính phủ quyết định hoặc được đánh giá rủi ro an ninh mạng theo Khung quản lý rủi ro an ninh mạng.

6.4. Tiêu chí xác định cấp độ 4

Hệ thống thông tin cấp độ 4 là hệ thống có một trong các tiêu chí sau:

- Hệ thống thông tin xử lý thông tin bí mật nhà nước hoặc hệ thống phục vụ quốc phòng, an ninh khi bị phá hoại sẽ làm tổn hại nghiêm trọng tới an ninh quốc gia.

- Hệ thống thông tin quốc gia phục vụ phát triển Chính phủ điện tử hoặc hệ thống cơ sở hạ tầng thông tin phục vụ hoạt động của các cơ quan, tổ chức trên phạm vi toàn quốc, yêu cầu vận hành 24/7 và không chấp nhận ngừng vận hành mà không có kế hoạch trước.

- Hệ thống thông tin điều khiển công nghiệp trực tiếp phục vụ điều khiển, vận hành hoạt động bình thường của các công trình xây dựng cấp I theo phân cấp của pháp luật về xây dựng.

- Hệ thống thông tin khác do Thủ tướng Chính phủ quyết định hoặc được đánh giá rủi ro an ninh mạng theo Khung quản lý rủi ro an ninh mạng.

6.5. Tiêu chí xác định cấp độ 5

Hệ thống thông tin cấp độ 5 là hệ thống có một trong các tiêu chí sau:

- Hệ thống thông tin xử lý thông tin bí mật nhà nước hoặc hệ thống phục vụ quốc phòng, an ninh, mang tính chiến lược khi bị phá hoại sẽ làm tổn hại đặc biệt nghiêm trọng tới an ninh quốc gia.

- Hệ thống thông tin phục vụ lưu trữ dữ liệu tập trung đối với một số loại hình thông tin, dữ liệu đặc biệt quan trọng của quốc gia.

- Hệ thống cơ sở hạ tầng thông tin quốc gia phục vụ kết nối liên thông hoạt động của Việt Nam với quốc tế.

- Hệ thống thông tin điều khiển công nghiệp trực tiếp phục vụ điều khiển, vận hành hoạt động bình thường của công trình xây dựng cấp đặc biệt theo phân cấp của pháp luật về xây dựng hoặc công trình quan trọng liên quan đến an ninh quốc gia theo pháp luật về an ninh quốc gia

- Hệ thống thông tin khác do Thủ tướng Chính phủ quyết định hoặc được đánh giá rủi ro an ninh mạng theo Khung quản lý rủi ro an ninh mạng.

VI. THẨM QUYỀN, TRÌNH TỰ, THỦ TỤC, XÁC ĐỊNH CẤP ĐỘ ĐỐI VỚI HỆ THỐNG THÔNG TIN

1. Thẩm quyền thẩm định và phê duyệt cấp độ

1.1. Đối với hệ thống thông tin được đề xuất là cấp độ 1 hoặc cấp độ 2

- Đơn vị chuyên trách về an ninh mạng của chủ quản hệ thống thông tin thực hiện thẩm định, phê duyệt hồ sơ đề xuất cấp độ đối với hệ thống thông tin được đề xuất là cấp độ 1 hoặc cấp độ 2, gửi báo cáo chủ quản hệ thống thông tin.

1.2. Đối với hệ thống thông tin được đề xuất là cấp độ 3

- Đơn vị chuyên trách về an ninh mạng của chủ quản hệ thống thông tin thực hiện thẩm định hồ sơ đề xuất cấp độ;

- Chủ quản hệ thống thông tin phê duyệt hồ sơ đề xuất cấp độ.

1.3. Đối với hệ thống thông tin được đề xuất là cấp độ 4 hoặc cấp độ 5

- Bộ Công an chủ trì, phối hợp với chủ quản hệ thống thông tin và các bộ, ngành có liên quan thực hiện thẩm định hồ sơ đề xuất cấp độ hệ thống thông tin, trừ hệ thống thông tin quân sự và hệ thống thông tin cơ yếu của cơ quan, tổ chức thuộc Ban Cơ yếu Chính phủ. Bộ Công an chủ trì thực hiện thẩm định hồ sơ đề xuất cấp độ đối với hệ thống thông tin của cơ quan, tổ chức thuộc phạm vi quản lý của Bộ Công an;

- Bộ Quốc phòng chủ trì thực hiện thẩm định hồ sơ đề xuất cấp độ đối với hệ thống thông tin quân sự;

- Ban Cơ yếu Chính phủ chủ trì thực hiện thẩm định hồ sơ đề xuất cấp độ đối với hệ thống thông tin cơ yếu của cơ quan, tổ chức thuộc Ban Cơ yếu Chính phủ;

- Chủ quản hệ thống thông tin phê duyệt hồ sơ đề xuất cấp độ đối với hệ thống thông tin cấp độ 4; phê duyệt phương án bảo đảm an ninh mạng đối với hệ thống thông tin cấp độ 5;

- Thủ tướng Chính phủ phê duyệt Danh mục hệ thống thông tin cấp độ 5 (Danh mục Hệ thống thông tin quan trọng về an ninh quốc gia).

1.4. Trường hợp đơn vị chuyên trách về an ninh mạng đồng thời được chủ quản hệ thống thông tin giao quản lý, vận hành hệ thống thông tin, việc tổ chức thẩm định Hồ sơ đề

xuất cấp độ được thực hiện theo một trong các phương án sau đây:

- Đơn vị chuyên trách về an ninh mạng trình chủ quản hệ thống thông tin giao một đơn vị trực thuộc có đủ năng lực chủ trì, tổ chức thẩm định;

- Đơn vị chuyên trách về an ninh mạng trình chủ quản hệ thống thông tin thành lập Hội đồng thẩm định độc lập thực hiện nhiệm vụ thẩm định Hồ sơ đề xuất cấp độ.

1.5. Trường hợp xác định cấp độ đối với dự án đầu tư xây dựng mới hoặc mở rộng, nâng cấp hệ thống thông tin

- Chủ đầu tư xây dựng thuyết minh đề xuất cấp độ, lồng ghép vào nội dung của báo cáo nghiên cứu khả thi, dự án khả thi ứng dụng công nghệ thông tin hoặc báo cáo đầu tư của dự án, gửi cơ quan thẩm định, trình cơ quan có thẩm quyền phê duyệt báo cáo nghiên cứu khả thi; dự án khả thi ứng dụng công nghệ thông tin hoặc báo cáo đầu tư theo quy định của pháp luật về đầu tư và quy định tại Nghị định số 331.

- Trong trường hợp thuê dịch vụ công nghệ thông tin:

+ Đơn vị chủ trì thuê dịch vụ xây dựng thuyết minh đề xuất cấp độ, lồng ghép vào nội dung của kế hoạch, dự án thuê dịch vụ, gửi cơ quan thẩm định, trình cơ quan có thẩm quyền phê duyệt theo quy định của pháp luật về thuê dịch vụ công nghệ thông tin và quy định của Nghị định số 331;

+ Đơn vị cung cấp dịch vụ có trách nhiệm phối hợp với chủ quản hệ thống thông tin, đơn vị chủ trì thuê dịch vụ cập nhật thông tin trong hồ sơ đề xuất cấp độ theo hiện trạng hạ tầng đã cài đặt để tổ chức thẩm định, phê duyệt.

2. Trình tự, thủ tục xác định cấp độ

2.1. Lập hồ sơ đề xuất cấp độ

- Đơn vị vận hành hệ thống thông tin lập hồ sơ đề xuất cấp độ theo hướng dẫn tại mục 3 Phần VI văn bản này;

- Đối với hệ thống thông tin được đề xuất là cấp độ 1 hoặc cấp độ 2: Đơn vị vận hành hệ thống thông tin gửi hồ sơ đề xuất cấp độ tới đơn vị thẩm định để thực hiện thẩm định theo hướng dẫn tại tiểu mục 1.1 mục 1 Phần VI của văn bản này;

- Đối với hệ thống thông tin được đề xuất là cấp độ 3: Đơn vị vận hành hệ thống thông tin gửi hồ sơ đề xuất cấp độ tới đơn vị thẩm định để thực hiện thẩm định theo hướng dẫn tại tiểu mục 1.2 mục 1 Phần VI của văn bản này;

- Đối với hệ thống thông tin được đề xuất là cấp độ 4 hoặc cấp độ 5:

+ Đơn vị vận hành hệ thống thông tin gửi hồ sơ đề xuất cấp độ tới đơn vị chuyên trách về an ninh mạng của chủ quản hệ thống thông tin để xin ý kiến chuyên môn về sự phù hợp của đề xuất cấp độ và phương án bảo đảm an ninh mạng hệ thống thông tin theo cấp độ;

+ Đơn vị vận hành hệ thống thông tin trình chủ quản hệ thống thông tin hồ sơ đề xuất cấp độ gửi tới cơ quan thẩm định quy định tại điểm a, điểm b hoặc điểm c khoản 3 Điều 18 Nghị định số 331.

2.2. Thẩm định hồ sơ đề xuất cấp độ

- Nội dung thẩm định hồ sơ đề xuất cấp độ bao gồm:

+ Sự phù hợp về việc đề xuất cấp độ;

+ Sự phù hợp của phương án bảo đảm an ninh mạng hệ thống thông tin trong thiết kế sơ bộ, thiết kế thi công hoặc tài liệu có giá trị tương đương theo cấp độ tương ứng;

+ Sự phù hợp của phương án bảo đảm an ninh mạng hệ thống thông tin trong quá trình vận hành hệ thống theo cấp độ tương ứng.

- Thời gian phản hồi đối với các hồ sơ chưa hợp lệ: Đối với hệ thống thông tin đề xuất cấp độ, thời gian phản hồi, hướng dẫn bổ sung tối đa là 05 ngày làm việc kể từ ngày nhận hồ sơ.

- Thời gian thẩm định hồ sơ xác định cấp độ:

+ Đối với hệ thống thông tin đề xuất cấp độ 3, thời gian thẩm định tối đa là 15 ngày làm việc kể từ ngày nhận đủ hồ sơ hợp lệ;

+ Đối với hệ thống thông tin đề xuất cấp độ 4 hoặc cấp độ 5, thời gian thẩm định tối đa là 25 ngày làm việc kể từ ngày nhận đủ hồ sơ hợp lệ.

2.3. Phê duyệt đề xuất cấp độ

- Đối với hệ thống thông tin được đề xuất là cấp độ 1 hoặc cấp độ 2: đơn vị chuyên trách về an ninh mạng của chủ quản hệ thống thông tin phê duyệt đề xuất cấp độ, gửi báo cáo chủ quản hệ thống thông tin;

- Đối với hệ thống thông tin được đề xuất là cấp độ 3 hoặc cấp độ 4: đơn vị vận hành hệ thống thông tin trình chủ quản hệ thống thông tin phê duyệt đề xuất cấp độ;

- Đối với hệ thống thông tin được đề xuất là cấp độ 5:

+ Trên cơ sở kết quả thẩm định hồ sơ đề xuất cấp độ, Bộ Công an chủ trì, phối hợp với các bộ, ngành, cơ quan, tổ chức, cá nhân có liên quan trình Thủ tướng Chính phủ phê duyệt Danh mục hệ thống thông tin quan trọng về an ninh quốc gia;

+ Đơn vị vận hành hệ thống thông tin trình chủ quản hệ thống thông tin phê duyệt phương án bảo đảm an ninh mạng.

2.4. Đối với hệ thống thông tin cấp độ 3, cấp độ 4 được xác định thuộc Danh mục hệ thống thông tin quan trọng về an ninh quốc gia. Các đơn vị thực hiện trình tự, thủ tục xác định cấp độ đối với hệ thống thông tin như đối với hệ thống thông tin được đề xuất cấp độ 5.

3. Hồ sơ đề xuất cấp độ

Hồ sơ đề xuất cấp độ bao gồm:

(1) Tài liệu mô tả, thuyết minh tổng quan về hệ thống thông tin.

(2) Tài liệu thiết kế là một trong những tài liệu sau:

- Đối với dự án đầu tư xây dựng mới hoặc mở rộng, nâng cấp hệ thống thông tin: thiết kế sơ bộ hoặc tài liệu có giá trị tương đương;

- Đối với hệ thống thông tin đang vận hành: thiết kế thi công đã được cấp có thẩm quyền phê duyệt hoặc tài liệu có giá trị tương đương.

(3) Tài liệu thuyết minh về việc đề xuất cấp độ căn cứ trên các tiêu chí theo quy định của pháp luật.

(4) Tài liệu thuyết minh phương án bảo đảm an ninh mạng theo cấp độ tương ứng.

(5) Ý kiến về mặt chuyên môn của đơn vị chuyên trách về an ninh mạng đối với hệ thống thông tin đề xuất cấp độ 4 hoặc cấp độ 5.

VII. KIỂM TRA AN NINH MẠNG

1. Công tác kiểm tra

- Nội dung kiểm tra, đánh giá việc tuân thủ quy định của pháp luật về bảo đảm an ninh mạng hệ thống thông tin theo cấp độ, bao gồm:

+ Kiểm tra, đánh giá tuân thủ đối với chủ quản hệ thống thông tin theo quy định tại Điều 31 Nghị định số 331, bao gồm: việc thực hiện thành lập/chỉ định đơn vị chuyên trách/bộ phận chuyên trách về an ninh mạng của chủ quản hệ thống thông tin theo quy định tại khoản 1 Điều 31 Nghị định số 331; việc thực hiện lập Hồ sơ đề xuất cấp độ, tổ chức thẩm định, phê duyệt Hồ sơ đề xuất cấp độ theo quy định đối với các hệ thống thông tin thuộc phạm vi quản lý; việc triển khai phương án bảo đảm an ninh mạng theo phương án trong Hồ sơ đề xuất cấp độ được phê duyệt đối với các hệ thống thông tin thuộc phạm vi quản lý; việc tổ chức thực hiện kiểm tra, đánh giá an ninh mạng và quản lý rủi ro an ninh mạng trong phạm vi cơ quan, tổ chức của mình theo quy định tại điểm c khoản 2 Điều 31 Nghị định số 331; việc tổ chức thực hiện đào tạo ngắn hạn, tuyên truyền, phổ biến, nâng cao nhận thức và diễn tập về an ninh mạng theo quy định tại khoản 3 Điều 31 Nghị định số 331;

+ Kiểm tra, đánh giá tuân thủ đối với đơn vị chuyên trách về an ninh mạng của chủ quản hệ thống thông tin theo quy định tại Điều 32 Nghị định số 331, bao gồm các nội dung: công tác tham mưu, tổ chức thực thi, đôn đốc, kiểm tra, giám sát công tác bảo đảm an ninh mạng; công tác thẩm định, phê duyệt hoặc cho ý kiến về mặt chuyên môn đối với Hồ sơ đề xuất cấp độ theo thẩm quyền quy định;

+ Kiểm tra, đánh giá tuân thủ đối với đơn vị vận hành theo quy định khoản 1 Điều 33 Nghị định số 331;

+ Kiểm tra, đánh giá việc tổ chức thực thi các biện pháp bảo đảm an ninh mạng theo phương án bảo đảm an ninh mạng được phê duyệt.

- Nội dung kiểm tra, đánh giá hiệu quả của các biện pháp bảo đảm an ninh mạng theo phương án bảo đảm an ninh mạng được phê duyệt, bao gồm:

+ Kiểm tra tính đầy đủ và phù hợp của Quy chế bảo đảm an ninh mạng theo phương án bảo đảm an ninh mạng về quản lý được phê duyệt;

+ Đánh giá việc tuân thủ các quy định, quy trình trong Quy chế bảo đảm an ninh

mạng trong quá trình vận hành, khai thác, kết thúc hoặc hủy bỏ hệ thống thông tin;

+ Đánh giá việc thiết kế hệ thống theo phương án bảo đảm an ninh mạng được phê duyệt;

+ Đánh giá việc thiết lập, cấu hình hệ thống theo phương án bảo đảm an ninh mạng được phê duyệt;

+ Kiểm tra việc cấu hình, tăng cường bảo mật cho thiết bị hệ thống, hệ điều hành, ứng dụng, cơ sở dữ liệu và các thành phần khác liên quan trong hệ thống.

- Nội dung kiểm tra, đánh giá phát hiện mã độc, lỗ hổng, điểm yếu, thử nghiệm xâm nhập hệ thống thông tin, bao gồm:

+ Dò quét, phát hiện mã độc, lỗ hổng, điểm yếu của hệ thống, thử nghiệm tấn công xâm nhập đối với các thiết bị hệ thống, hệ điều hành, ứng dụng, cơ sở dữ liệu và các thành phần khác liên quan trong hệ thống;

+ Việc duy trì, cập nhật và khắc phục các tồn tại, điểm yếu, lỗ hổng bảo mật đã được phát hiện trong quá trình vận hành hệ thống;

+ Đánh giá an toàn mã nguồn đối với phần mềm nội bộ;

+ Đưa ra phương án và kế hoạch xử lý lỗ hổng, điểm yếu và phương án cấu hình, tăng cường bảo mật đối với các nội dung kiểm tra được đánh giá là chưa đạt.

- Hình thức kiểm tra, đánh giá phát hiện mã độc, lỗ hổng, điểm yếu, thử nghiệm xâm nhập hệ thống thông tin, gồm 03 hình thức sau:

+ Kiểm tra, đánh giá hộp đen (Black box);

+ Kiểm tra, đánh giá hộp xám (Gray box);

+ Kiểm tra, đánh giá hộp trắng (White box).

2. Các biện pháp bảo vệ an ninh mạng

- Ban hành quy định về bảo đảm an ninh mạng trong thiết kế, xây dựng, quản lý, vận hành, sử dụng, nâng cấp, hủy bỏ hệ thống thông tin; tổ chức triển khai các biện pháp lưu trữ, sao lưu bảo vệ an ninh thông tin mạng và an ninh của các thành tố cấu thành hệ thống thông tin theo Tiêu chuẩn quốc gia về An ninh mạng - Hệ thống thông tin - Yêu cầu cơ bản.

- Xác định, lập hồ sơ đề xuất cấp độ hệ thống thông tin, hệ thống thông tin quan trọng về an ninh quốc gia; tổ chức thẩm định an ninh mạng đối với hồ sơ, thiết kế hệ thống thông tin theo trình tự, thủ tục thẩm định hồ sơ đề xuất cấp độ được quy định chi tiết trong Chương III của Nghị định số 331.

- Đánh giá điều kiện an ninh mạng hệ thống thông tin là hoạt động xem xét mức độ đáp ứng các điều kiện về an ninh mạng của hệ thống thông tin trước khi đưa vào vận hành, sử dụng.

+ Nội dung đánh giá điều kiện an ninh mạng bao gồm: chính sách, quy chế, quy trình bảo đảm an ninh mạng; tổ chức bộ máy, nhân sự phụ trách an ninh mạng; biện pháp quản lý và kỹ thuật bảo vệ an ninh mạng hệ thống thông tin; khả năng giám sát,

phát hiện, ứng phó và khắc phục sự cố an ninh mạng; việc tuân thủ quy định của pháp luật về an ninh mạng và các quy định có liên quan;

+ Đánh giá điều kiện an ninh mạng được thực hiện trong trường hợp: trước khi đưa hệ thống thông tin vào vận hành; khi có thay đổi lớn về chức năng, quy mô, công nghệ hoặc mức độ rủi ro an ninh mạng; theo yêu cầu của cơ quan có thẩm quyền;

+ Kết quả đánh giá điều kiện an ninh mạng là căn cứ để: xác định hệ thống thông tin đủ hoặc không đủ điều kiện đưa vào vận hành, sử dụng; yêu cầu bổ sung, hoàn thiện các biện pháp bảo đảm an ninh mạng; phục vụ công tác quản lý nhà nước về an ninh mạng.

- Áp dụng biện pháp quản lý, biện pháp kỹ thuật theo quy định tại Điều 29, Điều 30 Nghị định số 331, Tiêu chuẩn quốc gia về An ninh mạng - Hệ thống thông tin - Yêu cầu cơ bản và các tiêu chuẩn, quy chuẩn kỹ thuật về an ninh mạng khác theo quy định của pháp luật.

- Việc kiểm tra, giám sát việc tuân thủ quy định và đánh giá hiệu quả của các biện pháp quản lý, kỹ thuật được thực hiện theo hướng dẫn tại Điều 27 Nghị định số 331.

+ Hoạt động kiểm tra, giám sát và đánh giá hiệu quả được thực hiện: định kỳ theo cấp độ hệ thống thông tin và mức độ rủi ro an ninh mạng; thường xuyên thông qua hoạt động giám sát an ninh mạng; đột xuất khi có dấu hiệu vi phạm quy định về bảo đảm an ninh mạng hoặc nguy cơ mất an ninh mạng; theo yêu cầu của cơ quan có thẩm quyền;

+ Việc đánh giá hiệu quả các biện pháp bảo đảm an ninh mạng phải bảo đảm: xác định được mức độ hiệu quả của các biện pháp trong việc giảm thiểu rủi ro an ninh mạng; đánh giá khả năng đáp ứng yêu cầu bảo vệ hệ thống thông tin theo cấp độ; làm căn cứ để điều chỉnh, bổ sung hoặc thay thế các biện pháp quản lý và kỹ thuật không còn phù hợp;

+ Kết quả kiểm tra, giám sát và đánh giá hiệu quả là căn cứ: để tổ chức khắc phục, xử lý các tồn tại, điểm yếu, lỗ hổng bảo mật; phục vụ công tác quản lý nhà nước về an ninh mang.

- Bộ trưởng Bộ Công an quy định về hoạt động giám sát an ninh mạng, ứng phó, khắc phục sự cố an ninh mạng đối với hệ thống thông tin.

VIII. CHẾ ĐỘ BÁO CÁO, ĐIỀU KHOẢN CHUYỂN TIẾP

1. Chế độ báo cáo

- Các đơn vị thực hiện báo cáo theo Mẫu số 08 ban hành kèm theo Nghị định số 331 định kì hàng năm hoặc đột xuất theo đề nghị của cơ quan có thẩm quyền.

- Đơn vị chuyên trách về an ninh mạng, đơn vị vận hành gửi báo cáo tới chủ quản hệ thống thông tin trước ngày 20/12 hằng năm.

- Chủ quản hệ thống thông tin gửi báo cáo Bộ Công an trước ngày 25/12 hằng năm.

- Kỳ chốt số liệu báo cáo định kỳ hằng năm tính từ ngày 15/12 năm trước đến ngày 14/12 của kỳ báo cáo.

- Ngoài ra, để đảm bảo số liệu tổng hợp, tham mưu báo cáo kết quả cho UBND Thành phố, đề nghị các đơn vị đồng gửi báo cáo về CATP (qua Phòng An ninh mạng) trước ngày 10/12 hằng năm *(đây là thời hạn tổng hợp nội bộ của Thành phố, không thay thế thời hạn pháp lý theo quy định tại Nghị định số 331).*

2. Điều khoản chuyển tiếp

Đối với hệ thống thông tin đang trong quá trình đầu tư, xây dựng trước ngày 01/7/2026, các cơ quan, tổ chức liên quan thực hiện theo Điều 39 Nghị định số 331; trong thời hạn 06 tháng kể từ ngày Luật An ninh mạng số 116/2025/QH15 có hiệu lực phải hoàn thành việc thẩm định, phê duyệt cấp độ theo quy định tại Nghị định số 85/2016/NĐ-CP; trong thời hạn 12 tháng kể từ ngày Luật có hiệu lực phải đảm bảo điều kiện, tiêu chuẩn, biện pháp bảo vệ an ninh mạng tương ứng với cấp độ theo Nghị định số 331.

IX. CÔNG TÁC TỔ CHỨC BẢO ĐẢM AN TOÀN THÔNG TIN THEO MÔ HÌNH 4 LỚP

- Hệ thống thông tin sau khi được phê duyệt Hồ sơ đề xuất cấp độ, cần được triển khai đầy đủ phương án bảo đảm an ninh mạng bao gồm: Thiết kế, thiết lập hệ thống; quản lý, vận hành hệ thống theo Quy chế bảo đảm an ninh mạng được ban hành cùng Hồ sơ đề xuất cấp độ.

- Để triển khai phương án bảo đảm an toàn hệ thống thông tin một cách tổng thể, đồng bộ và hiệu quả, cơ quan tổ chức cần tổ chức triển khai toàn diện, thực chất công tác bảo đảm an ninh mạng theo mô hình 4 lớp.

- Tổ chức triển khai toàn diện, thực chất công tác bảo đảm an ninh mạng theo mô hình 4 lớp là việc triển khai đầy đủ 4 lớp bảo vệ bao gồm: (1) Lực lượng tại chỗ; (2) Tổ chức hoặc doanh nghiệp giám sát, bảo vệ chuyên nghiệp; (3) Tổ chức hoặc doanh nghiệp độc lập kiểm tra, đánh giá định kỳ; (4) Kết nối, chia sẻ thông tin với hệ thống giám sát quốc gia.

- Trên cơ sở đó, Công an Thành phố đề nghị các cơ quan, đơn vị trên địa bàn triển khai toàn diện, thực chất công tác bảo đảm an ninh mạng theo mô hình 4 lớp đối với các hệ thống thông tin thuộc phạm vi quản lý cụ thể như sau:

1. Lực lượng tại chỗ - Lớp 1

Lực lượng tại chỗ là lớp thứ nhất trong tổ chức bảo đảm an ninh mạng theo mô hình 4 lớp. Lớp này giúp cơ quan, tổ chức kiện toàn lực lượng tại chỗ và nâng cao năng lực của cán bộ chuyên trách để triển khai các lớp tiếp theo của Mô hình 4 lớp.

Nội dung triển khai Lớp 1. Lực lượng tại chỗ bao gồm các nội dung: (1) Kiện toàn lực lượng tại chỗ; (2) Nâng cao năng lực; (3) Mạng lưới.

1.1. Kiện toàn lực lượng tại chỗ

- Người đứng đầu cơ quan, tổ chức trực tiếp chỉ đạo, trong trường hợp cần thiết

có thể giao thêm 01 Lãnh đạo cấp phó của mình đảm nhận nhiệm vụ thường trực, giúp người đứng đầu;

- Theo Điều 31 Nghị định số 331, người đứng đầu đơn vị chủ quản hệ thống thông tin phải chỉ định bộ phận chuyên trách về an ninh mạng thuộc đơn vị chuyên trách về công nghệ thông tin, trong trường hợp chưa có đơn vị chuyên trách về an ninh mạng độc lập;

- Thành lập đội bảo đảm an ninh mạng/ứng cứu sự cố liên ngành theo hướng chuyên nghiệp, cơ động với sự tham gia của đại diện các cơ quan, tổ chức trực thuộc do đơn vị chuyên trách làm thường trực.

1.2. Nâng cao năng lực

Một số nội dung trọng tâm cơ quan, tổ chức cần triển khai để nâng cao năng lực tại chỗ bao gồm:

- Khuyến nghị bố trí chuyên gia an ninh mạng (bao gồm cả chuyên gia thuê ngoài) đáp ứng tiêu chuẩn kỹ năng về an ninh mạng.

- Xây dựng kế hoạch và tổ chức đào tạo chuyên sâu về an ninh mạng cho nhân sự chuyên trách; hàng năm tổ chức đào tạo, tuyên truyền tới toàn thể cán bộ, công chức, viên chức, người lao động thuộc phạm vi quản lý.

- Xây dựng kế hoạch và hàng năm tổ chức tuyên truyền, nâng cao nhận thức và phổ biến kiến thức về an ninh mạng tới toàn thể cán bộ, công chức, viên chức, người lao động thuộc phạm vi quản lý.

- Tổ chức diễn tập thực chiến tối thiểu 01 lần/năm đối với hệ thống thông tin cấp độ 3 trở lên.

1.3. Mạng lưới

Các đơn vị kiện toàn nhân sự tham gia Đội ứng cứu sự cố an ninh mạng Thành phố trong đó giao Phòng An ninh mạng là thành viên thường trực điều phối các hoạt động, đồng thời đăng kí tham gia mạng lưới ứng cứu sự cố do Trung tâm VNCERT thuộc Cục An ninh mạng - Bộ Công an điều phối.

2. Giám sát bảo vệ - Lớp 2

- Giám sát, bảo vệ là lớp thứ 2 trong Mô hình 4 lớp giúp triển khai giải pháp giám sát, bảo vệ chuyên nghiệp cho các hệ thống thông tin thuộc phạm vi quản lý. Một số điểm các đơn vị cần lưu ý khi triển khai lớp giám sát, bảo vệ như sau:

+ Mỗi hệ thống thông tin được xác định, phê duyệt đầy đủ các biện pháp bảo đảm an toàn hệ thống thông tin theo cấp độ. Việc triển khai Lớp 2 giám sát bảo vệ hệ thống thông tin là việc tổ chức triển khai các giải pháp nhằm đáp ứng đầy đủ các yêu cầu an toàn theo phương án được phê duyệt trong Hồ sơ đề xuất cấp độ.

+ Đối với hệ thống Cấp độ 1 và 2: Thực hiện giám sát log lớp mạng cơ bản và cập nhật tình hình lây nhiễm mã độc từ thiết bị đầu cuối về Trung tâm An ninh mạng Thành phố.

+ Hệ thống Cấp độ 3 trở lên (hoặc hạ tầng dùng chung của Thành phố): Bắt buộc phải cấu hình giám sát đầy đủ và chuyên sâu 24/7 trên cả 04 thành phần (Mạng, Máy chủ, Ứng dụng, Đầu cuối), đồng thời, thiết lập kết nối thời gian thực về Trung tâm An ninh mạng Thành phố để phân tích tương quan và cảnh báo tức thời.

+ Hệ thống thông tin có các máy chủ ứng dụng cần được triển khai tập trung tại Trung tâm dữ liệu tích hợp của Thành phố để được giám sát, bảo vệ tập trung.

+ Ưu tiên sử dụng các giải pháp phòng, chống mã độc có chức năng quản lý tập trung và có thể kết nối, chia sẻ thông tin với hệ thống giám sát an ninh mạng của Công an Thành phố và Trung tâm giám sát An ninh mạng quốc gia.

- Các yêu cầu cơ bản đối với việc giám sát an ninh mạng đối với hệ thống cấp độ 3 trở lên được quy định tại Tiêu chuẩn quốc gia TCVN 14423:2026 về An ninh mạng - Hệ thống thông tin - Yêu cầu cơ bản.

3. Kiểm tra, đánh giá định kỳ - Lớp 3

- Kiểm tra định kỳ là hoạt động chủ động nhằm phát hiện những lỗ hổng bảo mật mà hệ thống giám sát tự động chưa phát hiện.

- Người đứng đầu của cơ quan, tổ chức là chủ quản hệ thống thông tin có trách nhiệm chỉ đạo, tổ chức thực hiện kiểm tra, đánh giá an ninh mạng và quản lý rủi ro an ninh mạng trong phạm vi cơ quan, tổ chức của mình; đồng thời, chịu trách nhiệm trước pháp luật về tính trung thực, đầy đủ và chính xác của kết quả đánh giá, cụ thể như sau:

+ Việc kiểm tra, đánh giá an ninh mạng và quản lý rủi ro an ninh mạng có thể được thực hiện theo hình thức tự đánh giá nội bộ, với điều kiện việc đánh giá phải do bộ phận hoặc đơn vị độc lập với đơn vị trực tiếp vận hành hệ thống thực hiện, tuân thủ biểu mẫu, tiêu chí và phương pháp đánh giá do cơ quan nhà nước có thẩm quyền ban hành;

+ Việc kiểm tra, đánh giá bởi tổ chức chuyên môn được cơ quan có thẩm quyền cấp phép; tổ chức sự nghiệp nhà nước có chức năng, nhiệm vụ phù hợp hoặc do tổ chức chuyên môn được cấp có thẩm quyền chỉ định thực hiện trong các trường hợp sau đây: hệ thống thông tin cấp độ 5 hoặc hệ thống thông tin quan trọng về an ninh quốc gia; khi xảy ra sự cố an ninh mạng nghiêm trọng hoặc có nguy cơ cao ảnh hưởng đến an ninh quốc gia, trật tự, an toàn xã hội; khi có thay đổi lớn về chức năng, phạm vi, kiến trúc hoặc công nghệ của hệ thống thông tin; khi có dấu hiệu việc tự đánh giá không bảo đảm tính trung thực, đầy đủ, chính xác; khi có yêu cầu của cơ quan nhà nước có thẩm quyền hoặc do chủ quản hệ thống thông tin tổ chức thực hiện;

- Ngoài ra các quy định cụ thể về hoạt động kiểm tra đánh giá an ninh mạng được quy định tại Điều 27 Nghị định số 331.

4. Kết nối, chia sẻ với hệ thống giám sát an ninh mạng quốc gia - Lớp 4

- Kết nối, chia sẻ dữ liệu giám sát về Trung tâm An ninh mạng quốc gia nhằm mục đích hỗ trợ đảm bảo an toàn không gian mạng quốc gia và hỗ trợ cơ quan, tổ chức trong việc giám sát bảo vệ hệ thống thông tin.

- Kết nối chia sẻ dữ liệu lớp 4 của cơ quan, tổ chức cần bảo đảm bao gồm các dữ

liệu sau:

+ Dữ liệu của hệ thống giám sát tập trung.

+ Dữ liệu phòng, chống mã độc tập trung.

- Kết nối, chia sẻ dữ liệu về Trung tâm An ninh mạng quốc gia, đảm bảo các yêu cầu kỹ thuật dưới đây:

+ Dữ liệu chia sẻ phải bảo đảm liên tục, không mất kết nối quá 01 ngày.

+ Dữ liệu chia sẻ phải bảo đảm tính đầy đủ và tuân thủ chuẩn kết nối theo các quy định tại hướng dẫn này.

+ Đối với dữ liệu giám sát cần chia sẻ đầy đủ các cảnh báo có mức độ nguy hiểm từ thấp đến nghiêm trọng, yêu cầu đơn vị **đảm bảo chia sẻ đầy đủ 100% các cảnh báo mức cao và nghiêm trọng.**

(Hướng dẫn kết nối, chia sẻ dữ liệu giám sát an ninh mạng và dữ liệu phòng, chống mã độc về Trung tâm An ninh mạng quốc gia được đính kèm tại Phụ lục I và Phụ lục II của Công văn này).

X. CÁC CÔNG TÁC KHÁC CÓ LIÊN QUAN

1. Thống kê, rà soát hệ thống thông tin phục vụ thành lập "Bản đồ số"

- Ngày 11/7/2026, Ban Chỉ đạo Trung ương về phát triển khoa học, công nghệ, đổi mới sáng tạo và chuyển đổi số ban hành Kế hoạch số 05-KH/BCĐTW về hành động 100 ngày xử lý các điểm nghẽn về chuyển đổi số trong hệ thống chính trị, trong số giao nhiệm vụ cho Bộ Công an chủ trì lập "Bản đồ số cấp độ an ninh mạng cho các hệ thống số của 04 khối và địa phương". Kể từ thời điểm tiếp nhận chức năng quản lý nhà nước về an ninh mạng từ Sở Thông tin và Truyền thông *(cũ)*, CATP đã có nhiều văn bản đề nghị các đơn vị thống kê, rà soát thực trạng triển khai công tác bảo đảm an ninh mạng đối với hệ thống thông tin theo cấp độ. Tuy nhiên, cho tới nay còn một số đơn vị chưa thực hiện việc thống kê, rà soát một cách đầy đủ, chính xác.

- Do đó, CATP tiếp tục đề nghị các đơn vị khẩn trương rà soát, thống kê theo biểu mẫu tại Phụ lục I đính kèm Công văn này đồng thời gửi kết quả về CATP để tập hợp, tham mưu UBND Thành phố trong công tác đảm bảo an toàn thông tin ***(trước ngày 25/10/2026)***. Sau thời gian này, các đơn vị chưa thống kê, đánh giá sẽ chịu trách nhiệm trước đơn vị chủ quản nếu hệ thống thông tin do đơn vị mình phát sinh vấn đề liên quan đến an toàn, an ninh thông tin.

2. Triển khai chia sẻ, kết nối hệ thống giám sát tại địa phương về Trung tâm An ninh mạng quốc gia

- Hiện Công an Thành phố đã tham mưu cho UBND Thành phố thực hiện việc triển khai hệ thống giám sát theo mô hình tập trung cho phép theo dõi tổng thể các nguy cơ tấn công mạng đối với các hệ thống thông tin trên địa bàn, đồng thời giảm thiểu được chi phí đầu tư *(Đề án xây dựng Trung tâm giám sát an ninh mạng Thành phố Hồ Chí Minh)*. Theo phương án này, log từ các hệ thống thông tin sẽ được gửi về và được quản lý tại hệ thống quản lý tập trung của Trung tâm giám sát an ninh mạng

Thành phố Hồ Chí Minh đồng thời được chia sẻ kết nối về Trung tâm An ninh mạng quốc gia đảm bảo các hệ thống thông tin trọng yếu trên địa bàn Thành phố được giám sát an ninh mạng 24/7.

- Hiện nay, Công an Thành phố đã triển khai song song hai giải pháp giám sát và chống mã độc cho thiết bị đầu cuối *(Kaspersky Enpoint, NCS EDR)* cho một số đơn vị trên địa bàn Thành phố đáp ứng một phần nhu cầu đảm bảo an ninh mạng cho hệ thống thông tin của toàn thành phố. Đề nghị các đơn vị tiếp tục hỗ trợ Công an Thành phố triển khai cài đặt các giải pháp đảm bảo an ninh mạng theo nhu cầu đã đăng kí trong thời gian tới.

- Đối với các đơn vị triển khai hệ thống giám sát độc lập đề nghị đăng kí kết nối chia sẻ dữ liệu giám sát về Trung tâm An ninh mạng quốc gia theo mẫu đính kèm tại Phụ lục II và Phụ lục III của Công văn này ***(trước ngày 25/10/2026)***.

- Đối với các đơn vị có hệ thống thông tin cấp độ 3 trở lên chưa triển khai các biện pháp giám sát hệ thống đề nghị nhanh chóng trao đổi với Công an Thành phố để được hỗ trợ triển khai cảm biến kết nối với Trung tâm An ninh mạng quốc gia bảo đảm hạ tầng trọng yếu được giám sát trong thời gian xây dựng, bổ sung các giải pháp giám sát của đơn vị.

Trên đây là hướng dẫn việc thực thi tổng thể, đồng bộ các biện pháp bảo đảm an ninh mạng cho các hệ thống thông tin thuộc phạm vi quản lý của các đơn vị. Trong quá trình thực hiện, nếu các đơn vị có khó khăn vướng mắc hoặc cần trao đổi thông tin vui lòng liên hệ đồng chí Thượng tá Nguyễn Văn Dũng - Phó Trưởng Phòng *(SĐT: 0522333344)* và đồng chí Đại uý Nguyễn Văn Hà - Phó Đội Trưởng Đội 2 *(SĐT: 0779567986)*, Phòng An ninh mạng - Công an Thành phố.

Công an Thành phố trao đổi với các đơn vị để triển khai thực hiện./.

Nơi nhận:
- Như trên;
- Đ/c Giám đốc;
- Văn phòng Thành ủy Thành phố;
- Văn phòng UBND Thành phố;
- Lưu: CATP, PA05 (Đ.T.Tài, …..b)

KT.GIÁM ĐỐC
PHÓ GIÁM ĐỐC

Đại tá Lê Công Anh